

Identity Establishment

Registration

Validate identity fields
Hash password (bcrypt)
Create User document
Optional OTP email

credentials

Login

Verify email + password
Issue access token (JWT)
Store refresh token
Return user profile

JWT issued

Protected Request

Extract Bearer token
Decode & verify JWT
Attach req.user
Proceed to controller

token ops

forgot password

middleware result

Token & Recovery Lifecycle

Token Lifecycle

Short-lived access token
Refresh token rotation
Logout single session
Logout all sessions
Invalidate on password change

token reset

Password Recovery

Send OTP to email
Verify OTP code
Reset password
Invalidate stale tokens
Rate-limited attempts

re-auth

Auth Outcome

200 authorized controller call
401 missing/expired token
403 invalid ownership
429 rate limit exceeded
Global error handler

Middleware Decision

authMiddleware

Decode JWT → verify expiry → lookup user → attach req.user → next()

valid

Authorized
controller proceeds

invalid

Denied

401 / 403 JSON error

Security — Session state is explicit: refresh tokens can be individually revoked without invalidating the stateless access-token verification path. The OTP recovery flow is rate-limited and time-bounded to prevent brute-force attacks. All sensitive operations log an audit trail.